Robert F. Kennedy, Jr., Secretary
Dr. Mehmet Oz, Administrator
Tom Keane, Assistant Secretary and National Coordinator

Department of Health and Human Services
Centers for Medicare & Medicaid Services
Re: [CMS-0042-NC] RIN 0938-AV68: Request for Information; Health Technology Ecosystem

Dear Secretary Kennedy, Administrator Oz, and National Coordinator Keane,

On behalf of the CARIN Alliance, we thank you for the opportunity to comment on this RFI. We thank the Administration for the efforts made to advance consumer access to data and information and the ability to use tools to advance their health.

The CARIN Alliance is a multi-sector group of stakeholders representing numerous hospitals, thousands of physicians, and millions of consumers, individuals, and caregivers. We are committed to enabling consumers and their authorized caregivers to easily get, use, and share their digital health information when, where, and how they want to achieve their goals. Specifically, we are promoting the ability for consumers and their authorized caregivers to gain digital access to their health information via open APIs.

B. Patients and Caregivers

1. Patient Needs

PC-1*: What health management or care navigation apps would help you understand and manage your (or your loved ones) health needs, as well as the actions you should take?*

a. What are the top things you would like to be able to do for your or your loved ones' health that can be enabled by digital health products?

The CARIN Alliance has worked with a number of individual patients, consumers, and caregivers, in addition to various organizations focused on consumer-access to health information. A number of priorities have been surfaced:

1. Aggregating my health information and the health information of my family/dependents.
    a. Using one login to access all of my providers so that critical information doesn't fall through the gaps due to human error or so I don't give up on aggregating my health information because I forget my login credentials.
    b. Proving my identity one time instead of at every stop to reduce the number of steps required before accessing critical information, thereby decreasing the risk that my health information will be compromised.
    c. Connecting to all of my providers through one digital tool to avoid "portalitis," decreasing my friction to access health information and increasing the likelihood that I will engage with my health data.
    i. Adding care partners of my choice through one digital tool, facilitating the ability of my spouse, children, or other care partner to help me coordinate and manage my health and health care.
    d. Accessing images electronically through a more centralized format.
    e. Accessing my claims information from my current and my past insurers, encouraging me to participate more fully as a health care consumer.
    f. Receiving actionable updates and prompts, helping me better participate in my care.
2. While scheduling appointments, reducing the friction to accessing my providers.

3. Finding information about my costs (copays, deductibles, pricing, ahead of procedures) and understanding my claims information, helping to make me a better health care consumer, avoid delays in care, and make sure I can afford my therapies.
4. Finding providers in my health insurance network, helping ensure that I avoid out-of-network encounters and surprise medical expenses.
5. Having the ability to share authoritative documentation like immunization registries, active medication lists and medication histories.
6. Having the ability to easily ask my prescribing practitioner to refill my prescription.
7. Having the ability to transfer my prescription order between different pharmacies to get the best price, based on my coverage.
8. Having more information at my fingertips to evaluate cost and health care quality of different in-network and out-of-network providers.

b. If you had a personal assistant to support your health needs, what are the top things you would ask them to help with?

1. Helping me get all of my health records into one place, including services I've received, medications that I need to take, appointments that are coming up, etc.
2. Helping me understand my costs.
3. Health navigator applications.
4. Helping me navigate care and social needs outside of health care, including care management, social work needs, educational resources, etc.
5. For patients with rare diseases or complex illnesses, helping me get second opinions or submit my health data for research.

PC-2*: Do you have easy access to your own and all your loved ones' health information in one location?*

a. If so, what are some examples of benefits it has provided?

b. If not, in what contexts or for what workflows would it be most valuable to use one portal or system to access all such health information?

c. Were there particular data types that were unavailable? What are the obstacles to accessing your complete health information electronically?

The biggest challenges for consumer-directed health data access are:

1. "Portalitis" (discussed elsewhere in our comments regarding digital identity).
2. Token practices that require consumers to keep re-connecting their data, instead of giving consumers the option to "set and forget" their permissions untill they decide to disconnect a connection.
    a. Note that this may be a combination of vendor practices or provider choice; whatever the reason, it is important to remedy this issue to avoid "portalitis."
3. Insufficient compliance with information blocking mandates to support patient access through HL7® FHIR®-based APIs.
    a. This is true for hospitals and MIPS-eligible clinicians and practice groups that are customers of certified API developers.
    b. This is also true of other licensed health care practitioners, including non-HIPAA providers.
    c. This is also true of labs, pharmacies, LTPAC providers, and diagnostic imaging centers.
4. The lack of a national mandate for all health plans to enable patient access APIs for members in their commercial lines of business.
5. Insufficient access for active military service personnel and veterans to their clinical data from the military health system.
6. The low volume of participants on trusted networks that actually respond to patient requests.
7. The lack of a national health care directory that accurately represents the relationships of individual licensed practitioners to different practice groups and health systems, in a way that makes it easy for consumers to accurately locate all the right API endpoints they need to connect their data.

***PC-3**: Are you aware of health management, care navigation, or personal health record apps that would be useful to Medicare beneficiaries and their caregivers?*

The CARIN Alliance has organized the website, myhealthapplication.com to help consumers, caregivers, patients, and care partners find personal health records and other consumer-facing applications that have attested to industry best-practices for privacy, security, transparency, and consent through the CARIN Code of Conduct. These applications may have functions across the areas of health management, care navigation, and PHR functions. The website can help anyone, including Medicare beneficiaries, discover trusted applications that can connect them with their health data.

We note, however, that many Medicare and Medicaid beneficiaries, members of QHP plans, patients, care partners, and consumers do not know about many PHRs or the utility of using such a tool. Once these individuals become aware of such tools, they often have challenges using something other than a provider's patient portal or a plan's member portal. We encourage CMS to consider ways to incentivize plans and providers to educate their members and patients about the availability of consumer-access tools, beyond a patient or member portal, and to encourage their use. This could be done during open-enrollment each year or during a "Welcome to Medicare" or annual wellness visit or in the My Medicare Portal. It could be encouraged during a medication reconciliation visit or during a virtual visit with a provider. However CMS chooses to incent or require this education, it is critical to the success and adoption of digital health tools and individual access policy initiatives that individuals are informed of the functionality and utility of various digital tools as well as informed about the options available to them.

***PC-4**: What features are missing from apps you use or that you are aware of today?*

Some of the major challenges to consumer-facing tools' utility lies not with the functions that are or are not included in PHRs or other consumer-facing applications. It is important to note that the APIs needed to enable a number of functions that would benefit consumers are not available or are proprietary and locked-off behind technology vendor or provider paywalls. Seeing schedule availability, canceling, rebooking, messaging, and requesting refills are all functions that must be enabled to ensure that consumer engagement is seamless and friction is reduced. Anything that patients can do in their EHR portal needs to have a matching open API to allow them to complete those functions in an application of their choice.

***PC-5**: What can CMS and its partners do to encourage patient and caregiver interest in these digital health products?*

CMS can:

1. Update Medicare Blue Button® 2.0 to give beneficiaries options to use a digital ID and "selfy" to demonstrate how it helps more beneficiaries connect their data at FHIR API endpoints.
2. Make sure Medicare Blue Button 2.0 allows beneficiaries to set the period of duration for an app to connect data to one year or indefinitely, in addition to shorter durations.
3. Update its Conditions of Participation to require CMS-regulated participants to provide accurate, neutral, fact-based authoritative consumer education about their patient access rights via their choice of application, and maintain a gallery of third-party applications that are already connected to their endpoints. They should attest that they have reviewed and, as needed, updated this gallery each quarter, similar to the way Certified API Developers are required to do with their service base URL listings.
4. Require this education to include information about how consumers can submit a request if they want a connection through a particular application, and include a link to a consumer-facing page that links back to the health tech complaint portal maintained by the ASTP/ONC.
5. Lead the way by demonstrating on Medicare.gov how this education and functionality can be presented.

6. And must, re-evaluate the Promoting Interoperability Performance Category. It does not provide adequate incentive for ACOs and MIPS-eligible clinicians to activate patient access APIs. It should be table stakes. If they haven't activated their patient access APIs, make it an automatic 0 score for the entire category. Also, publish guidance that failure to activate these APIs is presumptively information blocking conduct.
7. Update Medicare Advantage Conditions of Participation by requiring MAOs to post a link to a connected apps gallery in their STAR rating profile.
8. Require MAOs to add requirements in the network contracts for their in-network providers to maintain accurate listings of their connected apps gallery, and to maintain active patient access APIs throughout the contract term.
9. Update the CAHPS Survey with questions to beneficiaries to see if they are aware of their rights to connect their health data through their choice of application, both with their health plan and their in-network providers. Apply a strong weighting on this measure.
10. Create additional payment adjustments for CMS-regulated organizations that implement standardized APIs that support interactivity with third party apps for more seamless shoppable experiences, including SMART Health Card for immunization records, active medication lists and medication histories, consumer real time pharmacy benefit check, and digital insurance card.
11. Ensure the national health care directory being developed by CMS includes quality measures about individual licensed practitioners and medical practices, follows the Patient Brands and Endpoints sub-specification and provides updated specialty and sub-specialty codes that are confirmed by the preponderance of patients they see with specific complaints. This will help app developers more easily navigate patients and caregivers to the right care.

There are a number of challenges that consumers, patients, and caregivers have when using consumer-facing applications. Most of these challenges relate to the difficulty in connecting to the information that would be most useful to them. Many of these challenges could be addressed by CMS and its governmental partners, including:

1. Mandating the use of a third-party credential or identity, and requiring EHRs, providers, and CMS-regulated payers to accept those credentials without additional steps. Many consumers suffer from "portalitis," having to remember countless usernames or passwords to login to each provider or payer. Using a "login with" function, with an IAL2 credential, would go far in alleviating these challenges.
2. Consumer facing applications face a number of challenges when seeking to connect users to data sources. Many of these challenges have been catalogued with exhaustive detail by the app developer community within the CARIN Alliance.[1] Among these challenges, the more acute dynamics include:
    a. HL7® FHIR® endpoint discovery: Endpoint discovery is challenging. CMS and ASTP/ONC should aggregate and publish an HL7 FHIR endpoint directory. CARIN Alliance has published[2] a framework for what should be included in an endpoint directory on the HL7® website.
    b. Onboarding and registration: HL7® FHIR® endpoint data holders are often slow to register and onboard consumer-facing applications. CARIN recommends several standardized

[1] See the CARIN Alliance webpage under Developer Resources; specifically "Patient Access APIs in the Wild: Challenges with Scaling User Choice Without Special Effort," "Endpoint Discovery," "Registration and Onboarding," "FHIR Standard APIs with Related Support and Enablement Services," and "Patient Experience" (forthcoming).

[2] CARIN Alliance recommendations for a FHIR endpoint directory on the HL7 site: https://confluence.hl7.org/spaces/FHIR/pages/113672758/Endpoint+directory+implementations+and+frameworks?preview=/113672758/218828161/API%20Endpoint%20Directory%20Inputs_Confluence%20Version.xlsx

approaches, consistent with the Interoperability and Patient Access Rule that should be mandated more universally (links below[3]).

c. Ongoing support: Various technology vendors, including those that support providers and CMS-regulated payers, often struggle to support the standards-based APIs required for individual access queries. While entities subscribing to proprietary platforms or participating in specific application vendor programs at EHRs and payer systems get quick responses and fast fixes to technical issues, support for standards-based APIs can significantly lag.

3. The lack of support for consumer-facing applications, and the challenges that these tools have in accessing, and maintaining access to, individual access endpoints, creates unnecessary friction for beneficiaries, patients, and caregivers. When that friction is encountered, these individuals often abandon the tools or give up trying to find and access the necessary data. CMS and ASTP/ONC must do more to require EHRs, payer technology systems, and the data holders themselves to support consumer access, including streamlining the ability of consumer facing applications to act on behalf of their users. The vision articulated in the CURES Act of consumer access to their information without special effort will not be realized until this is more of a reality.

a. What role, if any, should CMS have in reviewing or approving digital health products?

The certification of digital health products has progressed significantly since the passage of the HITECH Act. Similarly, products regulated by both CMS and ASTP/ONC have advanced significantly. We believe there is now an opportunity to change the way that certification occurs at both ASTP/ONC and CMS:

1. ONC should change the definition of CEHRT (Certified Electronic Health Record Technology) to "API CEHRT" (Application Programming Interface Certified Electronic Health Retrieval Technology).
2. The ONC is able to redefine API CEHRT based on the original definition in the HITECH Act, which includes the adoption of standards in Section 3004 and defines health information technology as inclusive all of the "hardware, software,...or packaged solutions sold as services that are designed for or support the use by health care entities or patients for the electronic creation, maintenance, access, or exchange of health information." This definition could include EHRs, LIS, RIS, payer systems, API vendors, and cloud-based solutions—in effect any HIT that supports some or all ePHI or EHI.
3. API CEHRT should focus exclusively on certifying the HL7® FHIR® APIs and other common interfaces, including NCPDP's ePrescribing standards, that providers and payers send and receive and no longer certify the functionality within the EHRs or EDI X12 transactions where there is a viable HL7 FHIR alternative.
4. CMS should then point to the new definition of API CEHRT in their regulations to ensure consistency between providers and payers.
5. The APIs on ONC's Inferno Test Kit website should be supported by payers and providers and implemented within the next two years.

[3] Best Practice recommendations: Patient Access APIs in the wild: Introduction https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/684318a6dfde5e7b2fab0f3f_CARIN%20AppForum_Challenges%20to%20Scale%20of%20User%20Choice%20Without%20Special%20Effort_6.5.25.pdf
Best Practices: Endpoint Discovery https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/684319a14c893300be71bdcd_02%20Endpoint%20Discovery%20and%20Getting%20Started%20(6.5.25).pdf
Best Practices: Registration and Onboarding https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/684319f357f39ee05872f32e_03%20Registration%20and%20Onboarding%20(6.5.25).pdf
Best Practices: Standard APIs https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/68431a7c9e1a8892bd7fa658_04%20Standard%20APIs%20With%20Support%20and%20Related%20Enablement%20Services.pdf

a. We support the addition, within Inferno, to add service-level standards to API testing. Data should be present and confirmed as performant. Those standards could include response time, formatting via Inferno, and an open data quality scorecard like the PIQI framework,[4] which we would encourage all data holders to adopt.
b. We believe this is allowed in the current HITECH regulation[5] where it says, "We believe the types of standards envisioned by Congress in the HITECH Act that would be most applicable to HIT are standards that are technical, functional, or performance-based. For example, a technical standard could specify that the structure of a message containing a patient's blood test results must include a header, the type of test performed, and the results, and further, that message must always be put in that sequence and be 128 bits long; a functional standard could specify certain actions that must be consistently accomplished by HIT such as recording the date and time when an electronic prescription is transmitted; and a performance standard could specify certain operational requirements for HIT such as being able to properly identify a drug-allergy contraindication 99.99% of the time for patient safety purposes. With this in mind, we have chosen to define standard to mean: a technical, functional, or performance-based rule, condition, requirement, or specification that stipulates instructions, fields, codes, data, materials, characteristics, or actions."

6. Improve testing of production APIs by requiring the inclusion of a standard test patient in the production environment for all HL7 FHIR-based API, and publish detailed results of these automated tests publicly on Lantern every week (with a score out of 100).

b. What changes would enable timely access to high quality CMS and provider generated data on patients?

CMS should retain a light touch on app approval, but encourage attestation to codes of conduct (*e.g.*, the CARIN Code of Conduct) that enable apps to declare a high bar for privacy and security. CMS could accept submissions of outcomes data associated with these apps, and publish the apps in a directory along with their outcomes data and code of conduct attestation (similar to CARIN's MyHealthApplication website).

***PC-6**: What features are most important to make digital health products accessible and easy to use for Medicare beneficiaries and caregivers, particularly those with limited prior experience using digital tools and services?*

As noted above, some of the biggest challenges that consumers, and especially Medicare beneficiaries, experience revolve around the friction that is created when trying to access health information. Challenges include remembering usernames and passwords, disparate data sources and the challenges of tools connecting to those data sources, incomplete data, and many more. As outlined above, we encourage CMS to consider ways to reduce the friction associated with connecting to providers and payers while increasing the utility of PHRs and other health navigation applications by making sure current regulations are followed by EHRs, providers, payer-technology vendors, and CMS-regulated insurers. We believe the specific use-cases outlined in PC-1 above, as well as things like prior authorization notifications for consumers, would have great utility for consumers, specifically Medicare beneficiaries and their caregivers.

***PC-7**: If CMS were to collect real-world data on digital health products' impact on health outcomes and related costs, what would be the best means of doing so?*

As noted above, CMS could create a registry of health applications and request submissions of outcomes data tied to these apps. This could be as simple as a link to PubMed or other journal articles. AI could be used to summarize key points in a user-friendly way, or app owners could submit their own summaries.

[4] https://jira.hl7.org/browse/PSS-2597 and https://piqiframework.org/; the PIQI framework will become an informative standard by the September 2025 ballot cycle
[5] https://www.federalregister.gov/d/E9-31216/p-173

CMS should also offer funding to support outcomes-related research involving digital health tools. CMS may also be able to see this in health tech partnerships and case studies that are written after treatment-control studies. CMS could put out a request for these.

2. Data Access and Integration

PC-8*: In your experience, what health data is readily available and valuable to patients or their caregivers or both?*

a. What data is valuable, but hard to access for appropriate and valuable use?

1. Imaging data, including radiology images and pathology slides.
2. After visit summary data, which is often not available via API access today.
3. Claims data is available, but APIs are inconsistently implemented and difficult to access.

b. What are specific sources, other than claims and clinical data, that would be of highest value, and why?

c. What specific opportunities and challenges exist to improve accessibility, interoperability and integration of clinical data?

One opportunity for improving data integration is to support not only read access for patients but also structured, write-enabled interactions through trusted third-party applications and/or access to a patient's data on their app/portal of choice. This could allow individuals to submit and/or share home-monitoring data, self-reported health and medication updates, or preferences that inform care decisions. CMS could consider pathways to encourage bidirectional exchange as part of advancing consumer-facing API functionality and digital engagement.

PC-9*: Given that the Blue Button 2.0 API only includes basic patient demographic, Medicare coverage, and claims data, what additional CMS data sources do developers view as most valuable for inclusion in the API?*

a. What difficulties are there in accessing or utilizing these data sources today?

The Blue Button® 2.0 API currently only includes basic patient demographic, Medicare coverage, and claims data (Part A, B, D). This limited dataset prevents a comprehensive view of the patient's health status. Many data sources remain isolated in proprietary systems or are difficult to access.

b. What suggestions do you have to improve the Blue Button 2.0 API experience?

The Blue Button 2.0 API should be expanded to include additional data sources and adopt more advanced HL7® FHIR® implementation guides. Specifically:

1. Implement the APIs on ONC's Inferno Test Kit website for payers, including:
   a. CARIN Consumer Real-time Pharmacy Benefit Check.[6]
   b. CARIN Digital Insurance Card and API.[7]
   c. Da Vinci Payer Data Exchange (PDex).
   d. Da Vinci Plan Net.
   e. Da Vinci US Drug Formulary.
2. Improve developer support by providing a test sandbox, development environment, detailed technical documentation, and synthetic data for applications to test against.
3. Validate conformance to the regulations by testing APIs against the ONC's Inferno Test Kits.

c. Is there non-CMS data that should be included in the API?

[6] CARIN Real time Pharmacy Benefit Check: https://www.hl7.org/fhir/us/carin-rtpbc/; this is required in 7 states including California and Texas which both require the use of an API; this needs to be required nationally as well.

[7] CARIN IG for Digital Insurance Card: https://hl7.org/fhir/us/insurance-card/; Humana and Epic have this functionality in production today and have created more than 600,000 digital insurance cards that have been sent directly from the payer to the provider to the individual does not need to fill out a clipboard in the doctor's office. https://docushare-web.apps.external.pioneer.humana.com/Marketing/docushare-app?file=2630953 https://klasresearch.com/report/points-of-light-2025-payer-and-provider-partnerships-advancing-patient-care-and-roi-through-innovative-technologies/3580

The Patient API should facilitate access to price transparency data, prescription benefit information, and provider directory information. Specifically, implementing the Patient Cost Transparency HL7® FHIR® API Implementation Guide to support the ability of patients to determine their out-of-pocket costs would be valuable.

CDC data could also be useful in some contexts, specifically in terms of particular risks of the user based on where they live and/or known condition. An example of this is COPD. If the CDC "knows" there is a flu breakout in user's location the issuance of a health alert to that user would be useful.

***PC-10**: How is the Trusted Exchange Framework and Common Agreement™ (TEFCA™) currently helping to advance patient access to health information in the real world?*

TEFCA is moving closer toward becoming an operational, everyday system for health information exchange. TEFCA has established the necessary framework and governance structures (QHINs, Participants, and Subparticipants) that will enable nationwide health information exchange, including Individual Access Services (IAS). However, there are still significant challenges that limit the promise of IAS on TEFCA. As noted in other areas, identity management, patient matching, reciprocity expectations and other issues have slowed the adoption of IAS on TEFCA and limited the utility to patients and the tools they use.

The implementation of the 21st Century Cures Act, alongside TEFCA development, has pushed policy toward patient ownership of data. IAS within TEFCA will enable individuals, through the application of their choice, to query and obtain their medical records and other health information from multiple sources, including the ability to discover where their records may reside through record location technology.

a. Please provide specific examples.

1. Under the Common Agreement, a participant or subparticipant data holder may decline to return records in response to an IAS request—even if the request generates a single patient match—if the participant/subparticipant's local matching rules have not been met. The rationale for this policy is that, even with return of a single match in response to a query, there is no guarantee that the record is a 100% match—and participants/subparticipants perceive liability under HIPAA (or at least a requirement to notify) if there is a breach due to sending what turns out to be the wrong record.
2. The CARIN Alliance (of which we are a member) and other key interoperability stakeholders have asked OCR for further HIPAA guidance on this issue, but to date no action has been taken.
3. Consequently, one large certified EMR vendor is taking the position that response to individual access requests (IAS) through TEFCA should not include payload (actual records) but should instead be limited to a return of Hl7 FHIR endpoints of locations for the patient's record; the patient would then need to connect to each Hl7 FHIR endpoint in order to secure the payload. This places multiple steps in a process that should be seamless given other protections in place (required use of an approved IAL2 credentialed service provider and submission of a token indicating that the patient has been successfully identity proofed at IAL2 & AAL2).
4. At the same time, at least one other certified electronic medical record provider has demonstrated return of payload in response to a compliant IAS query.
5. CMS should use its authorities to incent or mandate the return of payload in response to an IAS query. To support this—and ease concerns of HIPAA provider data endpoints participating in TEFCA—HHS should issue guidance regarding liability for return of a wrong record even when safeguards are followed.

b. What changes would you suggest?

To advance TEFCA implementation for patient access, we recommend:

1. Implement standardized identity proofing using IAL2 credentialing with NIST 800-63-3 standards and the CARIN Credential Policy for trust alignment, with federation via UDAP Trust Community.
2. Require all Designated QHINs to complete cross-network IAS testing on both sides of IHE Document Exchange APIs (that is, as a requesting and responding QHIN) within 12 months of signing the Common Agreement, and similarly with HL7® FHIR®-based APIs as they are being deployed.
3. Update the RCE's QHIN Participant/Sub-Participant Directory with information indicating which OIDs are responding to IAS Queries, and which have successfully responded with records for IAS purposes, and make time-stamped histories of IAS responses query-able. Also, support interoperability between the RLS directory and the national digital health care directory that CMS wants to build. More transparency exists if the RLS accurately represents the parent-child relationships of affiliated OIDs. Make the RLS Directory public.
4. Modify the TEFCA governance structure to ensure more representation by IASPs, specifically on the Governing Council, and the Participant/Subparticipant Caucus.
5. Clarify that TEFCA's reciprocity requirements are different for non-HIPAA IASPs than for other Participants and Sub-Participants. The TEFCA Terms of Participation v1.0 (April 2024) and TEFCA Exchange Purpose SOP v4.0 (January 16, 2025) make clear that IASPs that are Non-HIPAA Entities are not required to respond, but given the stance that several QHINs are taking, we believe a crystal clear policy clarification is needed to remove conditions of reciprocity as a current barrier to wider IAS exchange on TEFCA. OCR has long-standing guidance that patient requests cannot be conditioned on acceptance of other obligations.[8] IASPs have a choice whether to support reciprocal exchange, but that must be with the patient's consent.
6. Work with OCR to update the TEFCA Common Agreement and TEFCA Security Incident Reporting SOP v1.0 (July 1, 2024) to clarify that all wrong records shared over networks and exchanges with Requestors (including IASPs) are always considered breaches, but are also subject to the low probability of compromise analysis. That means all Requestors have a duty to report wrong records to Responders, not just IASPs. Under the low probability of compromise, guidance should explain how the breach is not reportable when IASPs and other Responders sign onto the Terms of Participation, which require among other things that Non-HIPAA Entities accept relevant standards set forth in the HIPAA Security Rule, HIPAA Privacy Rule and HIPAA Breach Notification Rule. Notably, the same analysis will support exchange for public health purposes and government benefits determination as well. CARIN Alliance has engaged the ASTP/ONC staff repeatedly on this topic in 2024 and before that engaged the OCR staff as recently as December 2022. The next step is for OCR to be re-engaged, to consider our analysis, and take action with policy guidance or rulemaking.
7. TEFCA's ultimate viability depends on trust, which depends most on transparency and individual participation. We endorse recommendations from Josh Mandel: For TEFCA to earn public trust and achieve widespread adoption, it must be designed from the ground up with robust, user-friendly mechanisms for individual transparency (knowing who accessed their data) and control (managing how it's shared) at the network level, with corresponding obligations for participating EHRs to honor these preferences. IAS serves as the great "unlock" for public trust to be achieved and maintained.
8. Address privacy & consent management capabilities using identity-linked consent artifacts, OAuth 2.0-based user-managed authorization flows, and federated consent via UDAP Authorization Extension Objects.
9. Simplify technical integration through SMART on HL7® FHIR® for initial access, UDAP Dynamic Client Registration for scalable onboarding, and certificate-based client identity with digital certificate validation.
10. Reduce privacy and security compliance burdens by adopting HL7® *FAST* Security IG, implementing UDAP JWT-based client authentication, and using privacy-protective attribute release.

[8] For example (Private practice may not condition a patient's access to PHI on an agreement not to publish commentary about the practice) https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/examples/all-cases/index.html

11. Improve patient trust through reusable IAL2 credentials from certified CSPs, implementing the CARIN Credential Policy[9] for policy equivalency, and supporting multiple authentication pathways.
12. Establish credential federation, allowing digital identities verified by one Credential Service Provider to be accepted by a HL7 FHIR endpoint that uses its own or a different Credential Service Provider without requiring duplicate identity verification. The HL7 *FAST* Security and Identity IGs provide stakeholder consensus-based approaches to this.

c. What use cases could have a significant impact if implemented through TEFCA?

High-impact use cases for TEFCA implementation include:

1. IAL2 credential with Record Locator Services using SMART on HL7 FHIR EHR portal authentication, enabling consumers to access health information across multiple provider portals with a single credential.
2. IAL2 credential with XCPD demographics match across multiple Health Information Exchanges, creating a single credential usable across multiple health information networks.
3. IAL2 credential using OpenID Connect with single or multiple QHINs, returning either CDA or HL7 FHIR resources to IAS Providers, streamlining authentication and supporting both document and API-based access.
4. Facilitated HL7 FHIR using HL7 *FAST* Security IG, allowing QHINs to return HL7 FHIR endpoints instead of data directly for secure querying.
5. Facilitated HL7® FHIR® with B2B User Authorization Extension Object, supporting complex authorization models across both consumer and business use cases.
6. Cross-provider credential acceptance demonstrating one credential issued by one CSP could be accepted by a HL7 FHIR endpoint that has not integrated that CSP into its system, establishing true identity federation in health care.

TEFCA could unlock new value by supporting direct patient contributions to their health record using a combination of structured HL7 FHIR write transactions and other means for clinicians to access patient contributions, *e.g.*, access to their PHR app/portal where direct writes are not appropriate. For example, enabling a patient to upload medication adherence logs or self-reported health goals through an application of their choice—validated by a credentialed identity—could significantly enhance data completeness and enable more personalized care planning, especially for chronic disease management.

A lot of angst expended over purpose of use and downstream secondary use can be resolved through consumer-mediated health data access and sharing. Consumer-directed access and exchange is a huge "unlock" for secondary uses like clinical trial matching and life insurance underwriting and post-market surveillance. But consumers are understandably concerned about "dark" data flows. Transparency for patients through individual access will help us move forward with network-based exchange for health care operations and other permitted HIPAA uses.

d. What standards are currently working well to advance access and existing exchange purposes?

Several standards work well for health information exchange, though not all are fully implemented within TEFCA yet:

1. SMART on HL7 FHIR is widely implemented across the industry and provides immediate feasibility for IAS exchange.
2. OAuth 2.0 technologies effectively support IAL2 credentials aligned with NIST requirements.

[9] CARIN Credential Policy which can be used by TEFCA to enable full interoperability between API-based Credentialing Service Providers and PKI-based ones (DirectTrust); combines the NIST 800-53, 800-63, and RFC 3467 trust frameworks together as one single credentialing policy. https://docs.google.com/document/d/1w7YE3WuFsgo7JIaGRNLu2gw1v_z8F3fT/edit

3. The IHE Document Exchange XCPD API support secure, interoperable access for demographic matching between systems.
4. The CARIN Alliance's work since 2016 has advanced consumer-directed exchange of health information and digital identity solutions.

e. What standards are not currently in wide use, but could improve data access and integration?

Promising emerging standards that could significantly improve data access include:

1. HL7® *FAST* Security (required standard by January 1, 2026, under TEFCA) offers improved capabilities including certificate-based authentication and enhanced security controls.
2. HL7 *FAST* Identity includes requirements for creating, managing, and federating Digital Identity including a Digital Identifier, as well as best practice patient matching, leveraging the certificate-based trust in HL7 *FAST* Security, although we do not agree on the different "sub-identity levels" (IAL1.6, 1.8, etc.) beyond what is spelled out in the NIST 800-63-3 guidelines. None of those "sub-levels" are currently supported by industry or by the certification bodies like Kantara International. We need to stick to the actual NIST 800-63-3 guidelines (IAL2, AAL2).
3. OpenID Connect Federation 1.0 enables credential federation across different service providers.
4. NIST 800-63-3 IAL2 compliant credentials, PKI certificate validation, and signed JWTs with authorization extension objects strengthen confidence in who has been authenticated.
5. The NCPDP Patient Experience Identifier could help improve patient matching without compromising privacy.
6. UDAP Dynamic Client Registration enables scalable onboarding of applications. Open ID Federation[10] also should be examined as an alternative identity federation protocol accepted by CSPs outside of health care.

f. Are there redundant standards, protocols, or channels that should be consolidated?

Areas needing consolidation include:

1. Fragmented identity verification standards across QHINs, Participants, and Subparticipants create redundant verification processes.
2. Non-standardized acceptance of IAL2 credentials creates unnecessary friction for consumers accessing health information across multiple systems.
3. The TEFCA technical framework needs standardized methods for passing authenticated credentials between QHINs. Toward this end, accreditation/certification bodies should publish the endpoints for keys used exclusively to sign services that meet accreditation requirements (consistent with each pairing of IAL/AAL, or higher, the relying party may desire), along with plain language stating that minimum identity and authentication assurance for which a key at that endpoint can be relied upon, as part of identifying who the accredited party is and when the accredited service is being used, to increase confidence in the binding to an identity issued by a certified Identity Provider.
4. Different trust frameworks (Carequality, DirectTrust) need a common credentialing policy establishing equivalency through standardized requirements for IAL2 OAuth and PKI credentials such as the CARIN Credentialing Policy.[11]
5. When there is an equivalent HL7® FHIR® standard available and in production such as the CARIN IG for Blue Button®[12], antiquated X12 EDI standards such as the X12 835 Health Care Claim Payment

[10] https://openid.net/specs/openid-federation-1_0.html
[11] https://docs.google.com/document/d/1w7YE3WuFsgo7JIaGRNLu2gw1v_z8F3fT/edit
[12] https://www.hl7.org/fhir/us/carin-bb/

and Remittance standard should no longer be required. This will prevent organizations from supporting two different transactional systems.

g. Are there adequate alternatives outside of TEFCA for achieving widespread patient access to their health information?

Direct connections via standard HL7 FHIR APIs have worked well to bootstrap the industry; however, it's still complex for digital health tools to connect to thousands of disparate endpoints. Thus, the need for a single endpoint that enables patients to access all of their data in a standard and reliable way is pressing.

***PC-12**: What are the most valuable operational health data use cases for patients and caregivers that would create more efficient care navigation or eliminate barriers to competition among providers or both?*

A highly valuable but underused workflow is digital presentation of insurance coverage during appointment scheduling. A standardized, QR-enabled insurance card format would allow for instantaneous eligibility confirmation, helping patients avoid surprises related to coverage and network status. CMS could support this by naming a national digital insurance card standard and encouraging health plans to implement it via their Patient Access API infrastructure. Additional advancements on good faith estimates and advanced EOBs are also crucial for patients to understand what their out-of-pocket costs are likely to be at the time of scheduling, rather than at the time-of-service delivery.

A critical operational use case is enabling patients to **track the status of prior authorization requests** via third-party apps or health plan portals. Delays and lack of transparency in the PA process often result in care disruptions. CMS should encourage implementation of standardized APIs that allow consumers to view the status, rationale, and estimated decision timelines for pending authorizations. CARIN and the Da Vinci Project have been exploring this consumer-focused workflow, which builds on CMS-0057-F principles of transparency and real-time data exchange.

Additionally, CMS should work to enable users to share their patient-generated health data with their care team in standard ways (see feedback above about standard ways to write data back to the EHR and/or access to the patient's data on their app/portal of choice). This may include information such as:

1. Activity.
2. Sleep quality.
3. Lab results from external sources.
4. Links to images.
5. Alerts about potential illness (or other regulated features).

3. Information Blocking and Digital Identity

***PC-13**: How can CMS encourage patients and caregivers to submit information blocking complaints to ASTP/ONC's Information Blocking Portal? What would be the impact?*

CMS can boost beneficiary-directed education on Medicare.gov about their right to submit government complaints if their health care providers or MAOs don't allow them access to their electronic health information through their choice of application.

CMS can add a link to a consumer-friendly complaint portal on Medicare.gov for authenticated beneficiaries, which links on the backend to ASTP/ONC's Info Blocking Portal.

CMS can require CMS-regulated payers to deliver similar education to Medicare beneficiaries, Medicaid enrollees and QHP members and include the same link on the home page of their member portals or the plan's home page.

Increased reporting would almost certainly improve consumer-directed data exchange. A good proof point is how HIPAA covered entity compliance with 45 CFR 164.524 has increased in direct response to stepped up OCR's investigation and enforcement of HIPAA individual access complaints. Also, publishing and

maintaining a scorecard causes covered entities to prioritize compliance, evidenced by a study conducted after Citizen Health first produced its individual access scorecard in 2019. Increased reporting aligns with the truism: "What doesn't get measured, and publicly reported, doesn't get improved."

PC-14: Regarding digital identity credentials:

a. What are the challenges today in getting patients/caregivers to sign up and use digital identity credentials?

The primary challenges today include fragmentation of identity systems across health care, lack of standardization, and the complexity of managing multiple credentials. Additionally, the limited ability to use a single digital credential means patients often have to sign up over and over again.

Patients currently navigate a disjointed set of portals to access their health information, making it nearly impossible to proactively manage their health information across different providers and systems. This creates significant downstream issues in identifying individuals across systems, costing the healthcare system millions of dollars.

Another often-forgotten challenge is the power of trust, and what happens when patients have low trust in the systems they interact with. With so many fragmented identity systems, today's certification standards don't leave users confident in the operator of a sign-in page presented to them. Of course they don't complete the flow. With one trusted source (*i.e.*, one Credential Service Provider that each patient or authorized representative elects to use, of the many choices available—or is offered as part of IAS—and some may elect to use more than one) that patients can start recognizing, we will be on our way to significantly less resistance to data sharing.

b. What could be the benefits if digital identity credentials were more widely used?

Federated credentials would dramatically reduce friction in accessing health information across portals, apps, and networks. Adopting standardized digital identity credentials would dramatically improve patient access by enabling a single identity across providers and payers. It also is a better security model (many portals have not yet updated their systems to a strong identity assurance minimum bar with multi-factor authentication, as required by the HL7® *FAST* Identity IG) while limiting the likelihood of patient lockout (a commercial CSP may be better-equipped to enable 24x7 support for forgotten credentials when escalating to repeated identity verification is potentially needed).

Federated credentials would allow patients to create their own single digital identity, aggregate their own health information with an application of their choice, and provide their insurance information digitally, eliminating redundant paperwork and improving care coordination.

c. What are the potential downsides?

As these proposals are implemented, we need the technology to be easily accessible to everyone, including those who live in underserved communities, lack strong technology knowledge themselves, or struggle to obtain and maintain valid forms of government ID.

d. How would encouraging the use of CSPs improve access to health information?

Widespread implementation of Credentialing Service Providers would eliminate the need for separate authentication systems at each provider and payer. This would streamline access to health information by accepting a NIST 800-63-3 IAL2 or higher certified identity provider as valid for a consumer to access their data and to create a login session using OpenID Connect, with data provided via an openly provided API.

e. What role should CMS/payers, providers, and app developers have in driving adoption?

CMS/Payers: Require implementation of NIST 800-63-3 IAL2 standards for identity verification and authentication and incentivize the adoption of identity federation across health systems.

Providers: Accept verified digital identities from certified IAL2 providers rather than maintaining separate identity systems. To successfully deploy digital identity credentials, health care organizations, payers, etc., who are managing identities today need to modify their systems to organize their records on unique identities, so that demographics that are shared in an ID token from Digital Identity/reusable credentials can confidently be "matched" to the correct person within their system. Otherwise, we have strong security in a credential that may be reused, but that credential may be allowed access to a different person's personal information and health data than is appropriate. The HL7 *FAST* Identity IG provides guidance on this topic, whether IdP integrations are done as one-off, more scalably integrated according to PKI-based trust via UDAP Tiered OAuth (securing CSP trust via PKI-based validation), or somewhere in-between.

App Developers: Incorporate standards like OpenID Connect and support identity federation.

f. How can CMS encourage patients to get digital identity credentials?

CMS should require that any system used for registration and login to access data on any health care network follow the NIST 800-63-3 digital identity guidelines for identity assurance level 2 (IAL2) and authenticator assurance level 2 (AAL2) for patient and provider identity and authentication. This requirement could be implemented within certification programs for providers and payers.

We encourage CMS to consider how it can leverage current federal and state government processes and functions, including login.gov (especially for VA use cases!) and state-level mDL/eDL efforts. Where a user has a government secured and verified identity, they should be able to use that to prove identity for medical records access AND portal login.

C: Providers

1. Digital Health Apps

PR-4*: What changes or improvements to standards or policies might be needed for patients' third-party digital products to have access to administrative workflows?*

Administrative workflows should accommodate not just viewing of provider schedules or forms but also patient-generated inputs—for example, enabling patients to pre-populate intake forms or submit supplemental data like medication logs or social history directly through apps. CMS could clarify that certified APIs should include HL7® FHIR® write support for this class of interactions, supported by patient consent and identity validation mechanisms.

One overlooked opportunity is the modernization of eligibility verification and benefits display using standards-based digital insurance cards. CMS should support the use of open, API-based insurance card formats—such as the **CARIN Digital Insurance Card IG**[13]—which provide real-time coverage details via a QR code or app display. This allows patients to carry accurate, up-to-date coverage information, streamlining registration, scheduling, and intake workflows without relying on legacy manual or paper-based processes.

CMS should clarify that administrative workflows, such as prior authorization, should support **patient-directed data access**. This includes surfacing PA status updates through consumer-facing APIs that are connected to the same adjudication engines used in provider-facing workflows. Aligning provider and patient experiences reduces confusion, improves adherence, and reinforces the role of the consumer as an informed participant in the care journey.

3. Digital Identity

PR-9*: How might CMS encourage providers to accept digital identity credentials from patients instead of proprietary logins?*

[13] https://hl7.org/fhir/us/insurance-card/

CMS should require that any system used for registration and login to access data on any health care network follow the NIST 800-63-3 digital identity guidelines for identity assurance level 2 (IAL2) and authenticator assurance level 2 (AAL2) for patient and provider identity and authentication. This requirement could be implemented within certification programs for providers and payers.

CMS can accelerate adoption of trusted identity credentials by endorsing **federated digital identity models** that allow patients to use one IAL2-verified login (*e.g.*, via ID.me, CLEAR, Login.gov) across systems. This approach was successfully demonstrated by CARIN in partnership with CMS, CommonWell, and Athenahealth, and as part of our digital identity federation proof of concept.[14] Providers will need implementation support and clear certification expectations to ensure that identity standards are met uniformly across networks.

Requiring the NIST 800-63-3 digital identity guidelines for identity assurance level 2 (IAL2) and authenticator assurance level 2 (AAL2) for patient and provider identity and authentication would strengthen identity and access management capabilities for each individual user on any network (providers, health plans, and individuals). This balances patient privacy by building transparency and trust that individuals are who they say they are and affords better identification of who each individual represents on any network.

***PR-10**: Regarding digital identity credentials:*

a. What are the challenges and benefits for providers?

Patients have not been involved in validating that they are who they say they are with their provider or health plan, which creates millions of dollars in downstream issues identifying individuals across systems. Enabling patients to use a consumer application and IAL2 digital identity provider (*e.g.*, CLEAR, ID.me, etc.) to prove their identity and authenticate themselves helps achieve cross-provider credential acceptance, eases provider burden, reduces redundant solutions, and saves on patient matching costs down the road if the provider updates a patient's demographics with the patient's credential.

Additionally, numerous trusted consumer-facing applications are on the rise, but many providers are having difficulty accessing health information on behalf of patients.

b. How would requiring their use improve access to health information?

Adopting standardized digital identity credentials would allow patients to aggregate their health information with an application of their choice and share their health information with their provider using the Patient Access API, improving care coordination and enabling providers to more proactively manage health information across different providers and systems.

D. Payers

***PA-2**: How can CMS encourage payers to accelerate the implementation and utilization of APIs for patients, providers, and other payers?*

CARIN notes the great work that has been accomplished by our member organization, Flexpa, to publish transparent compliance scores for the Patient Access API and other consumer-access tools (see: https://www.flexpa.com/blog/may-2025-state-of-the-payer-patient-access-api-report).

We also encourage CMS to consider our recommendations in response to question PC-3. Payers should make enrollees and members aware of the digital tools that are available to them and the data that they have access to during open enrollment and subsequent interactions. Payers should be required to outline the additional digital tools, beyond a member portal, that could be of use.

[14] https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/66635361bd8176cd6413cb97_Proof-of-Concept_Final-Report.pdf

CMS may also consider similar rulemaking to previous MAPD and Part D rules around real-time benefit tools. Plans should have the option to provide incentives to their members for using digital tools, specifically PHRs and RTBTs, that are outside of the plan-sponsors' environments.

***PA-3**: How can CMS encourage payers to accept digital identity credentials from patients and their partners instead of proprietary logins?*

CMS should require implementation of NIST 800-63-3 standards for identity verification and authentication and incentivize the adoption of identity federation across health systems. Widespread implementation of Credentialing Service Providers would eliminate the need for separate authentication systems at each provider and payer. This would streamline access to health information by accepting a NIST 800-63-3 IAL2 or higher certified identity provider as valid for a consumer to access their data and to create a login session using OpenID Connect, with data provided via an openly provided API. This would eliminate redundant paperwork and reduce the millions of dollars in downstream issues resulting in identifying individuals across systems.

***PA-4**: What would be the value to payers of a nationwide provider directory that included FHIR end points and used digital identity credentials?*

If CMS implemented a nationwide provider directory that included FHIR end points and used digital identity credentials it would be *immensely* valuable for payers, providers, and patients to digitally find who their provider is and how to connect to them with an application of their choice. This is the only way in which we can implement FHIR at scale across the country.

E: Technology Vendors, Data Providers, and Networks

1. Ecosystem

***TD-1**: What short term (next 2 years) and longer-term steps can CMS take to stimulate developer interest in building digital health products for Medicare beneficiaries and caregivers?*

1. Establish a centralized registry of approved or verified third-party applications, including those focused on preventive care, sleep, and chronic condition management. A testing environment would lower barriers for new entrants and validate interoperability.
2. Offer clear pathways for non-coverage product validation: Provide guidance on how digital health products can be evaluated based on real-world performance, health outcomes, and user engagement without requiring a full coverage determination. This encourages innovation while maintaining guardrails.
3. Explore offering reimbursement for evidence-based digital health tools: Tools such as wearables that demonstrate improved outcomes are often less expensive than comparable "clinical-grade" medical devices.

2. Digital Identity

***TD-3**: Regarding digital identity implementation:*

a. What are the challenges and benefits?

b. How would requiring digital identity credentials impact cybersecurity and data exchange?

Federated identity models using OpenID Connect protocols and NIST-aligned assurance levels improve both cybersecurity and user experience. By validating identity once through a certified credential service provider (CSP), individuals can authenticate across systems with confidence. CMS should standardize on this

approach within TEFCA, CEHRT, and the Patient Access API ecosystem, reducing redundant credentialing and improving match rates.

Requiring the NIST 800-63-3 digital identity guidelines for identity assurance level 2 (IAL2) and authenticator assurance level 2 (AAL2) for patient and provider identity and authentication would strengthen transparency and trust that individuals are who they say they are, enable better identification of who each individual represents on any network, and reduce phishing and other cybersecurity attacks for health care organizations and individuals to prevent individual's health care data from being breached.

c. What impact would mandatory use of the OpenID Connect identity protocol have?

Consumer identity for access to health care portals, personal health care applications, health care services (such as digital visits, condition management, and health devices) should use open standards and support OpenID Connect. It needs to be required for all data holders to ensure they can accept an IAL2 credential from another source. These services should also support Identity Federation and accept a NIST 800-63-3 IAL2 or higher certified identity provider as valid for a consumer to access their data and to create a login session using OpenID Connect, with data provided via an openly provided API.

Using open standards and supporting OpenID Connect for consumer identity, as well as adopting Open ID Federation or UDAP Tiered OAuth protocols, ensure all systems can accept an identity credential.

This promotes online patient registration that allows patients to create their own single digital identity, aggregate their own health information with an application of their choice, and provide their insurance information digitally.

3. Technical Standards and Certification

TD-5*: How could a nationwide provider directory of FHIR endpoints improve access to health information? Who should publish such a directory, and should users bear a cost?*

Having a central place for digital health tool developers to access FHIR endpoints is a good start, although not sufficient if the implementation of these endpoints is inconsistent or it's challenging to connect because of significant friction for app vendors to register. Ultimately, a central TEFCA via IAS would solve this problem, although in the spirit of optionality to see where the market goes, supporting a bootstrapped version of a directory would be a great first step. This could be hosted on Lantern with minimal additional cost.

F. Value-Based Care Organizations

1. Digital Health Adoption

VB-3*: What are essential health IT capabilities for value-based care arrangements?*

a. Examples include care planning, patient event notification, etc.

Patient-reported data submission capabilities—via secure, structured write transactions—are essential for value-based care models focused on engagement, adherence, and outcomes. Digital tools that allow patients to contribute to their longitudinal health record (*e.g.*, symptoms, health goals, lifestyle data) can enhance risk stratification, care planning, and quality reporting. CMS should consider promoting this capability in CEHRT criteria and VBC program design. Tools that allow patients to contribute to their longitudinal record while supporting care navigation are even more useful.

b. What other health IT capabilities have proven valuable?

3. Technical Standards

VB-11*: What specific interoperability challenges have you encountered in implementing value-based care programs?*

A notable challenge is the lack of support for consumer-submitted structured data. While Patient Access APIs enable information retrieval, current interoperability models rarely support authenticated write-back, which limits the ability to integrate real-time, patient-reported information into care workflows or digital quality measures. Aligning TEFCA guidance, ONC certification, and CEHRT policy with consumer-write capabilities would help close this gap.

VB-14*: How could implementing digital identity credentials improve value-based care delivery and outcomes?*

Adopting standardized digital identity credentials would dramatically improve patient access by enabling a single identity across providers and payers. This would allow patients to create their own single digital identity and aggregate their own health information with an application of their choice, improving care coordination and enabling patients and providers to more proactively manage health information across different providers and systems.